CISSP | SecurePay Practical Security Assessment

Hands-On Security Workbook — Complete Submission

Prepared as a practical working report

Document Item	Details
Project basis	CISSP Practical Assignment Workbook
Case organization	SecurePay Solutions Pvt. Ltd. — fictional mid-size payment-services company
Scope	Eight practical CISSP security domains specified in the workbook
Evidence approach	Reference architecture, lab evidence references, control tables and practical templates
Evidence disclaimer	Screenshots marked as reference evidence are documentation examples and are not claims of production execution.

Executive Summary

This report converts the supplied CISSP Practical Assignment Workbook into a structured, practical project report. The workbook requires practical work across Security and Risk Management, Asset Security, Security Architecture and Engineering, Communication and Network Security, Identity and Access Management, Security Assessment and Testing, Security Operations, and Software Development Security. It also emphasizes clarity, practical understanding, accurate risk/control identification, diagrams/configurations, and professional presentation.

A fictional mid-size payment-services organization, SecurePay Solutions Pvt. Ltd., is used as the working case so that the activities can be demonstrated consistently. The company scenario is a constructed lab example for the assignment and is not represented as a real organization.

Contents

- 1. Security and Risk Management
- 2. Asset Security
- 3. Security Architecture and Engineering
- 4. Communication and Network Security
- 5. Identity and Access Management
- 6. Security Assessment and Testing
- 7. Security Operations
- 8. Software Development Security

- 9. Evidence & Submission Notes
- 10. Conclusion

1. Security and Risk Management

Assignment requirement: select a mid-size company, perform a basic risk assessment with at least ten risks, propose treatment, and write a 1–2 page Information Security Policy.

1.1 Organization Profile

Attribute	Working Scenario
Organization	SecurePay Solutions Pvt. Ltd. (fictional)
Industry	Payment services / fintech
Size	Approximately 250 employees
Technology	Cloud workloads, corporate endpoints, APIs, databases, SaaS platforms
Critical information	Customer PII, payment tokens, transaction records, source code, credentials
Security objective	Protect confidentiality, integrity and availability while supporting business operations and compliance

1.2 Risk Assessment

ID	Risk	Impact	Treatment	Key Controls	Owner
R01	Ransomware affecting critical servers	High	Reduce	EDR, immutable backups, segmentation, IR testing	Security / IT
R02	Credential compromise / phishing	High	Reduce	MFA, awareness, conditional access, phishing lab exercises	IAM / Security
R03	Cloud misconfiguration exposing data	High	Reduce	CSPM, secure baselines, reviews, least privilege	Cloud / Security
R04	Third-party security failure	High	Transfer / Reduce	Due diligence, contracts, security clauses, monitoring	GRC / Procurement
R05	Unpatched critical vulnerability	High	Reduce	Vulnerability scanning, patch SLAs, exception process	IT / Security

R06	Data leakage from endpoints	Medium	Reduce	DLP, encryption, removable-media controls	Security / IT
R07	DDoS affecting public APIs	Medium	Transfer / Reduce	CDN/WAF, rate limiting, provider protection	Network / Cloud
R08	Unauthorized privileged access	High	Reduce	PAM, MFA, access reviews, session logging	IAM / Security
R09	Backup failure or unusable recovery point	High	Reduce	3-2-1 strategy, restore tests, monitoring	IT / DR
R10	Insider misuse of sensitive data	Medium	Reduce	Least privilege, logging, DLP, SoD	HR / Security
R11	Loss/theft of company laptop	Medium	Reduce	Full-disk encryption, MDM, remote wipe	IT
R12	Security control non-compliance	Medium	Reduce	Internal audit, CAPA tracking, management review	GRC

1.3 Risk Treatment Principles

- Avoid: discontinue an activity when its risk exceeds organizational tolerance and cannot be reasonably controlled.
- Reduce: implement preventive, detective, corrective or compensating controls to lower likelihood and/or impact.
- Transfer: contractually or financially share risk with a third party, while retaining appropriate oversight.
- Accept: formally acknowledge residual risk when it falls within approved risk appetite/tolerance.

1.4 Information Security Policy

Policy Area	Requirement
Purpose	Protect organizational information and technology assets through risk-based security governance and consistent control implementation.
Scope	Employees, contractors, systems, applications, cloud services, endpoints, networks, data and third parties handling company information.
Access Control	Access shall be based on business need, least privilege and role. Privileged access shall use MFA and be periodically reviewed.
Data Protection	Information shall be classified and protected according to

	sensitivity. Restricted and Confidential information shall use approved encryption mechanisms where appropriate.
Endpoint & Network Security	Managed endpoints shall use approved security controls. Network segmentation, secure protocols, firewalls and monitoring shall be implemented based on risk.
Vulnerability Management	Security vulnerabilities shall be identified, prioritized and remediated according to documented risk-based timelines.
Incident Management	Suspected security incidents shall be reported immediately through approved channels and handled through documented incident-response procedures.
Business Continuity	Critical services shall maintain recovery strategies, backups and periodic restoration/testing appropriate to business requirements.
Third Parties	Security requirements shall be incorporated into applicable contracts and supplier reviews.
Awareness	Personnel shall receive security awareness training appropriate to their role.
Compliance	Applicable legal, contractual and regulatory requirements shall be identified, monitored and addressed.
Enforcement	Violations may result in corrective action under applicable organizational procedures.
Review	This policy shall be reviewed at least annually and after significant changes to business, technology, threat landscape or regulatory requirements.

2. Asset Security

The workbook requires an asset inventory, classification into Public/Internal/Confidential/Restricted, handling rules, and an encryption exercise.

2.1 Asset Inventory

ID	Asset	Type	Classification	Reason	Owner
AST-001	Customer database	Data	Restricted	Customer PII / transactions	Database Team
AST-002	Payment-token repository	Data	Restricted	Payment-related tokens	Application Team
AST-003	Source-code repository	Application	Confidential	Proprietary code	DevOps
AST-004	Production API	Application	Restricted	Business-critical service	Application Team
AST-005	Employee HR records	Data	Confidential	Personnel information	HR

AST-006	Corporate laptops	Endpoint	Internal	Managed devices	IT
AST-007	Security logs / SIEM	Data	Confidential	Security telemetry	SOC
AST-008	Public website	Application	Public	Public information	Marketing / IT
AST-009	Backup repository	Data	Restricted	Recovery copies	IT
AST-010	Firewall configuration	Configuration	Confidential	Security configuration	Network Team
AST-011	IAM directory	System	Restricted	Identity and access data	IAM
AST-012	Vendor security records	Data	Confidential	Contracts / assessments	GRC

2.2 Classification Handling Rules

Classification	Handling Rules
Public	May be shared externally after approval; integrity should be maintained; no sensitive information.
Internal	Business use only; access limited to personnel/authorized third parties; use approved corporate storage.
Confidential	Need-to-know access; encryption in transit and at rest where appropriate; controlled sharing and retention.
Restricted	Strongest controls; least privilege; MFA/privileged controls where applicable; encryption; logging; restricted transfer and approved disposal.

2.3 CEH_Test_File.txt Encryption Procedure

1. Create a non-sensitive CEH_Test_File.txt for the exercise; do not use real customer or production data.
2. Open an approved encryption/archive tool such as 7-Zip and select the CEH_Test_File.txt.
3. Create a 7z archive and enable AES-256 encryption with a strong password.
4. Enable filename encryption where supported.
5. Store the CEH_Encrypted_Archive.7z only in an approved location and manage the password separately.
6. Attempt a controlled extraction to verify that the archive cannot be opened without the correct password.
7. Record the evidence, date, CEH_Test_File.txt and verification result.

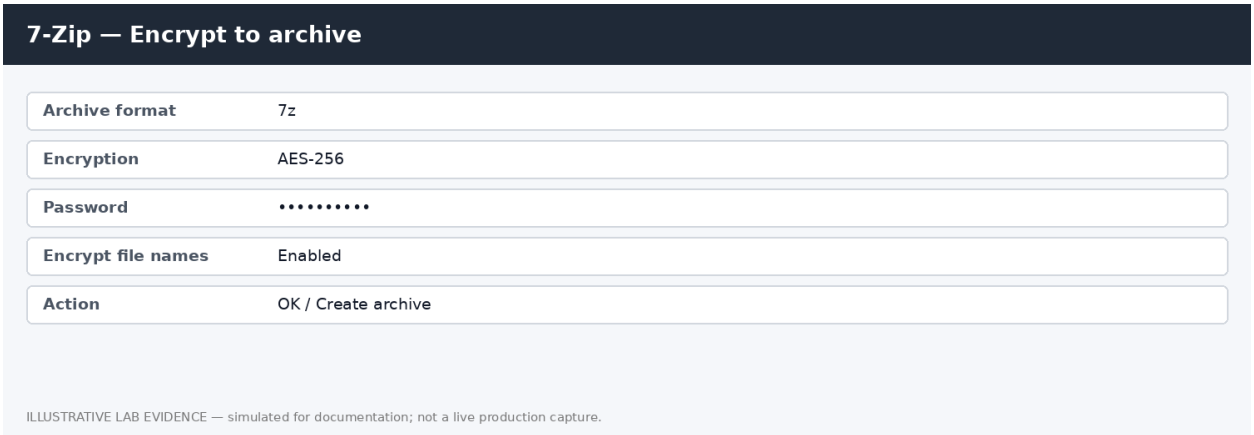


Figure 1 — 7-Zip encryption evidence reference for CEH_Test_File.txt. Insert the actual lab capture if execution evidence is required.

3. Security Architecture and Engineering

The workbook requires a basic architecture diagram, placement of controls, at least two hardware security options, and an explanation of layered security.

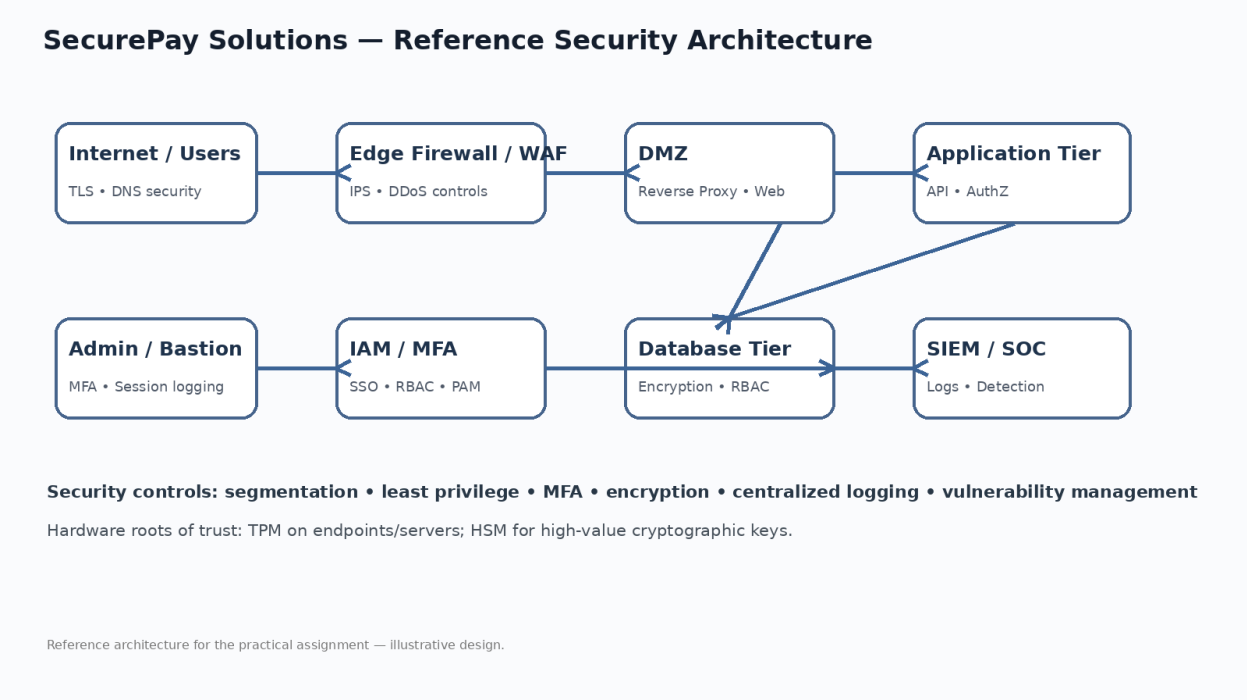


Figure 2 — SecurePay Solutions Pvt. Ltd. reference architecture with security-control placement.

3.1 Hardware-Based Security Options

Technology	Use
TPM (Trusted Platform Module)	Hardware-backed key storage, device identity/attestation and support for secure boot/disk-encryption workflows.
HSM (Hardware Security Module)	Dedicated hardware for generating, storing and using high-value cryptographic keys with strong administrative and audit controls.

3.2 Layered Security

Layered security (defense in depth) places multiple complementary controls across identity, endpoint, network, application, data and monitoring layers. For lab example, MFA can reduce account-compromise risk; segmentation can limit lateral movement; WAF controls can protect internet-facing applications; encryption can reduce the impact of data exposure; and centralized logging/SIEM can provide detection and investigation capability. The objective is not to rely on one control but to ensure that failure of one layer does not automatically result in complete compromise.

4. Communication and Network Security

The workbook requires firewall rule lab examples, secure protocol descriptions, packet capture evidence, and VLAN/DMZ segmentation.

4.1 Firewall Rule Examples

Rule	Source	Destination	Service	Action	Reason
FW-01	Internet	WAF-01 (10.20.60.10)	TCP/443	ALLOW	Public HTTPS service
FW-02	Internet	WEB-01 (10.20.60.20)	Any	DENY	Prevent direct access to protected tiers
FW-03	WEB-01 (10.20.60.20)	DB-01 (10.20.30.10)	TCP/5432	ALLOW	Only required application-to-database traffic
FW-04	User VLAN	ADMIN-01 (10.20.40.10)	Any	DENY	Limit lateral/admin access
FW-05	ADMIN-01 (10.20.40.10)	APP-01 (10.20.20.20)	TCP/22,443	ALLOW	Controlled administration
FW-06	Any	Any	Known malicious indicators	DENY	Threat-based blocking where validated

4.2 Secure Protocols

Protocol	Purpose
HTTPS	HTTP protected by TLS for confidentiality and integrity of web traffic.
TLS	Cryptographic protocol providing secure communication and server/client authentication where configured.
SSH	Encrypted remote administration and secure command execution.
SFTP	Secure file transfer over SSH.

IPsec	Network-layer protection commonly used for VPNs and secure site-to-site connectivity.

4.3 Packet Capture Evidence

The workbook allows Wireshark capture or tutorial screenshots when tools are unavailable. The following evidence is therefore provided as a CISSP-CEH-LAB capture. It demonstrates the expected TCP three-way handshake: SYN, SYN/ACK, ACK, followed by TLS traffic.

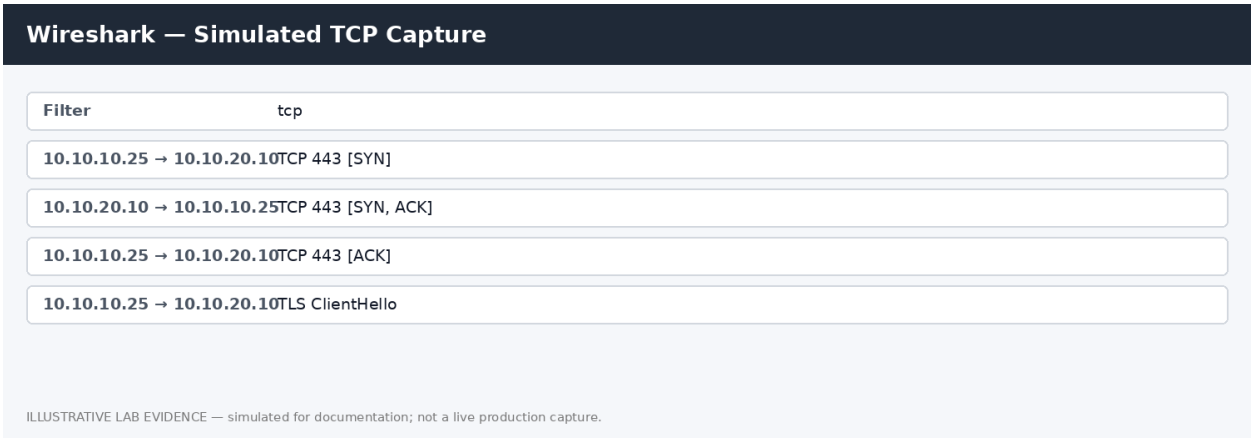


Figure 3 — Wireshark lab evidence reference showing a TCP handshake and TLS ClientHello. Insert the actual lab capture if required.

4.4 Network Segmentation

Segment	Example Contents	Control Objective
VLAN 10 — Users	Employee endpoints	Limit user-to-user and user-to-server exposure
VLAN 20 — Servers	Internal application services	Restrict access to approved service flows
VLAN 30 — Database	Sensitive databases	Allow only required application connections
VLAN 40 — Admin	Bastion/PAM/admin systems	Highly restricted privileged access
DMZ	WAF, reverse proxy, public-facing services	Separate internet-facing services from internal systems
VLAN 50 — Guest	GUEST-01 (10.20.50.10)	Internet-only; no corporate network access

5. Identity and Access Management

The workbook requires an RBAC chart, joiner/mover/leaver process, MFA demonstration/research, and an access-review checklist.

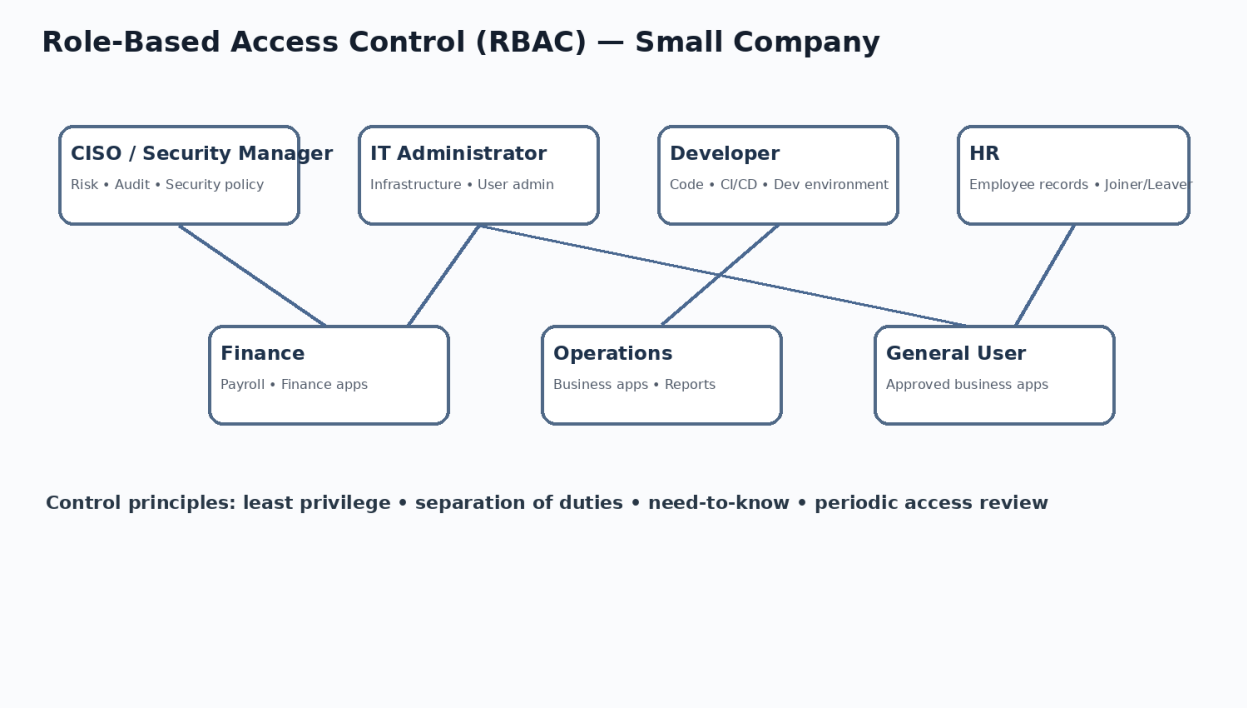


Figure 4 — RBAC model for the SecurePay Solutions Pvt. Ltd..

5.1 Joiner / Mover / Leaver Process

Stage	Activities	Control
Joiner	HR creates approved request; manager confirms role; IAM provisions minimum required access.	Approval + RBAC + MFA
Mover	Role change triggers access review; old privileges removed before new privileges are granted where practical.	Least privilege + SoD
Leaver	HR triggers termination workflow; IAM disables account; sessions/tokens revoked; assets recovered.	Timely deprovisioning
Privileged access	Separate privileged identity; MFA; PAM where available; logging and periodic review.	PAM + MFA + monitoring

5.2 MFA Demonstration

MFA combines two or more different authentication factors, such as something the user knows, has, or is. The following lab evidence illustrates a typical password-plus-authenticator flow.

MFA — Simulated Authentication Flow

Step 1	Username + password accepted
Step 2	Authenticator challenge generated
Step 3	User approves / enters one-time code
Step 4	Identity provider issues session/token
Result	Access granted

ILLUSTRATIVE LAB EVIDENCE — simulated for documentation; not a live production capture.

Figure 5 — MFA lab authentication flow.

5.3 Access Review Checklist

- Confirm user account ownership and employment status.
- Confirm access is still required for the current role.
- Review privileged and administrative access separately.
- Identify dormant, shared, orphaned and generic accounts.
- Validate MFA enrollment for required users.
- Check segregation-of-duties conflicts.
- Review recent joiner/mover/leaver tickets.
- Document exceptions with owner and expiry date.
- Obtain business/application-owner sign-off.
- Track remediation and retain evidence.

6. Security Assessment and Testing

The workbook requires a vulnerability scan or lab exercise, a penetration-test report template, OWASP Top 10 mitigations, and a quarterly audit checklist.

6.1 OpenVAS/Greenbone Vulnerability Scan

Because the source workbook permits a CISSP-CEH-LAB scan or screenshots where a tool is unavailable, the following is a controlled lab reference. It should be replaced with the actual scan output from WEB-01 (10.20.60.20) when execution evidence is required.

OpenVAS / Greenbone — Simulated Vulnerability Scan

Target	10.10.20.10 (LAB)
High	1 finding — TLS weak configuration
Medium	2 findings — missing headers / outdated package
Low	3 findings — informational
Status	Scan completed

ILLUSTRATIVE LAB EVIDENCE — simulated for documentation; not a live production capture.

Figure 6 — OpenVAS/Greenbone lab scan vulnerability-scan evidence.

6.2 Penetration Testing Report Template

Section	Required Content
Executive Summary	Scope, objective, overall risk themes
Scope	Systems, IP ranges, applications, exclusions
Rules of Engagement	Dates, authorization, constraints, contacts
Methodology	Reconnaissance, validation, exploitation where authorized, reporting
Findings	ID, title, severity, affected asset, evidence, impact
Remediation	Recommended fix, owner, target date
Retest	Validation of remediation and residual findings
Evidence	Screenshots/logs/requests/responses with sensitive data redacted
Conclusion	Overall observations and next actions

6.3 OWASP Top 10 — One-Line Mitigations

OWASP Category	One-Line Mitigation
A01 Broken Access Control	Enforce server-side authorization, deny by default and validate object-level permissions.
A02 Cryptographic Failures	Use strong modern cryptography, protect keys, and avoid exposing sensitive data unnecessarily.
A03 Injection	Use parameterized queries, safe APIs, input validation and contextual output handling.
A04 Insecure Design	Threat-model critical workflows and design security requirements before implementation.
A05 Security Misconfiguration	Harden defaults, disable unnecessary features and continuously validate secure configuration.
A06 Vulnerable and Outdated Components	Maintain an inventory, monitor vulnerabilities and patch/upgrade within defined SLAs.
A07 Identification and Authentication Failures	Use MFA, secure session management, strong credential controls and rate limiting.
A08 Software and Data Integrity Failures	Protect build/update pipelines, verify integrity and control dependencies.
A09 Security Logging and Monitoring Failures	Centralize relevant logs, protect them from tampering and alert on meaningful events.
A10 SSRF	Restrict outbound destinations, validate URLs and isolate

	application network privileges.

6.4 Quarterly Security Audit Checklist

- Review policy and standard changes.
- Verify asset inventory and owners.
- Review access and privileged accounts.
- Validate vulnerability/patch metrics.
- Sample security logs and alerts.
- Review backup and restoration evidence.
- Check incident tickets and CAPA closure.
- Review third-party security assessments.
- Verify endpoint encryption/MDM coverage.
- Review network firewall rule changes.
- Check security-awareness completion.
- Report exceptions to management.

7. Security Operations

The workbook requires a ransomware Incident Response Plan, Business Continuity Plan, unusual log review, and a one-page Disaster Recovery approach.

7.1 Ransomware Incident Response Plan

Phase	Key Activities	Primary Responsibility
Preparation	IR plan, contacts, backups, EDR, tabletop exercises	Security / IT / GRC
Detection	Validate alert, identify affected host/user, preserve initial evidence	SOC
Containment	Isolate affected endpoints/servers, disable compromised accounts, block indicators	SOC / IT
Eradication	Remove persistence, remediate vulnerabilities, reset credentials as required	IT / Security
Recovery	Restore from verified clean backups, validate controls, monitor closely	IT / Application
Post-Incident	Root cause, lessons learned, CAPA, evidence retention and management report	Security / GRC

7.2 Business Continuity Plan — Outline

Component	Content
Business Impact Analysis	Identify critical processes, dependencies and recovery

	priorities.
RTO / RPO	Define recovery time and recovery-point requirements per critical service.
Continuity Strategies	Redundancy, alternate processing, backups, manual workarounds and supplier alternatives.
Roles	Incident/continuity leadership, technical recovery, business validation and communications.
Communications	Approved internal/external communication paths and escalation contacts.
Testing	Tabletops, failover/recovery tests and documented lessons learned.

7.3 Unusual Log Review — Sample

Timestamp	Event	Assessment	Action
10:14:03	18 failed logins for one privileged account	Suspicious brute-force pattern	Investigate source; verify user; consider temporary containment
10:18:44	Successful privileged login after failures	Potential compromise	Validate MFA/session and source; correlate endpoint/network logs
10:21:12	New admin account created outside change window	High-risk change	Validate authorization; disable if unauthorized; preserve evidence
10:25:39	Large outbound transfer from database host	Potential data exfiltration	Investigate destination, process and user context

7.4 Disaster Recovery Approach

A practical DR approach begins with a business impact analysis and identification of recovery priorities. Critical applications should have documented RTO/RPO targets, dependency maps and recovery procedures. Backups should follow an appropriate resilient strategy, include offline/immutable protection where justified, and be periodically restored to prove usability. Recovery should be performed in a controlled sequence: infrastructure, identity/network dependencies, databases, applications, integrations, and business validation. After recovery, heightened monitoring should remain in place until service stability is confirmed. Test results, gaps and corrective actions should feed back into the continuity and security programs.

8. Software Development Security

The workbook requires code-risk review, 10–15 secure coding guidelines, a STRIDE threat model, and a secure DevSecOps pipeline.

8.1 Example Code-Risk Review

For the practical exercise, a small illustrative API pattern is reviewed. The following risks are representative review findings, not findings from a real application.

Finding	Risk	Recommended Control
Hard-coded credential	Credential exposure through source repository	Use secret manager/environment injection; rotate exposed secrets
String-built SQL query	SQL injection risk	Parameterized queries / safe ORM APIs
Missing authorization check	Horizontal/vertical privilege escalation	Enforce server-side authorization on every sensitive operation
Verbose error response	Information disclosure	Return generic client errors; log details securely server-side
Unvalidated redirect/URL	Abuse of redirect or SSRF-like behavior	Allowlist destinations and validate URLs

8.2 Secure Coding Guidelines

- Validate input at trust boundaries and apply allowlist validation where practical.
- Use parameterized queries and safe database APIs.
- Enforce authorization on the server for every protected function and object.
- Never hard-code passwords, API keys or private keys in source code.
- Use approved cryptographic libraries and protect encryption keys.
- Use secure session management with appropriate expiration and invalidation.
- Return generic errors to users and avoid exposing stack traces.
- Encode output according to the destination context to reduce injection risks.
- Keep dependencies inventoried and patched; monitor for known vulnerabilities.
- Apply secure defaults and disable unnecessary features.
- Protect secrets through an approved secret-management mechanism.
- Log security-relevant events without recording unnecessary sensitive data.
- Require peer review and security testing before production deployment.
- Protect CI/CD credentials and restrict build/deployment permissions.
- Use dependency, SAST, DAST and/or IaC scanning according to application risk.

8.3 STRIDE Threat Model

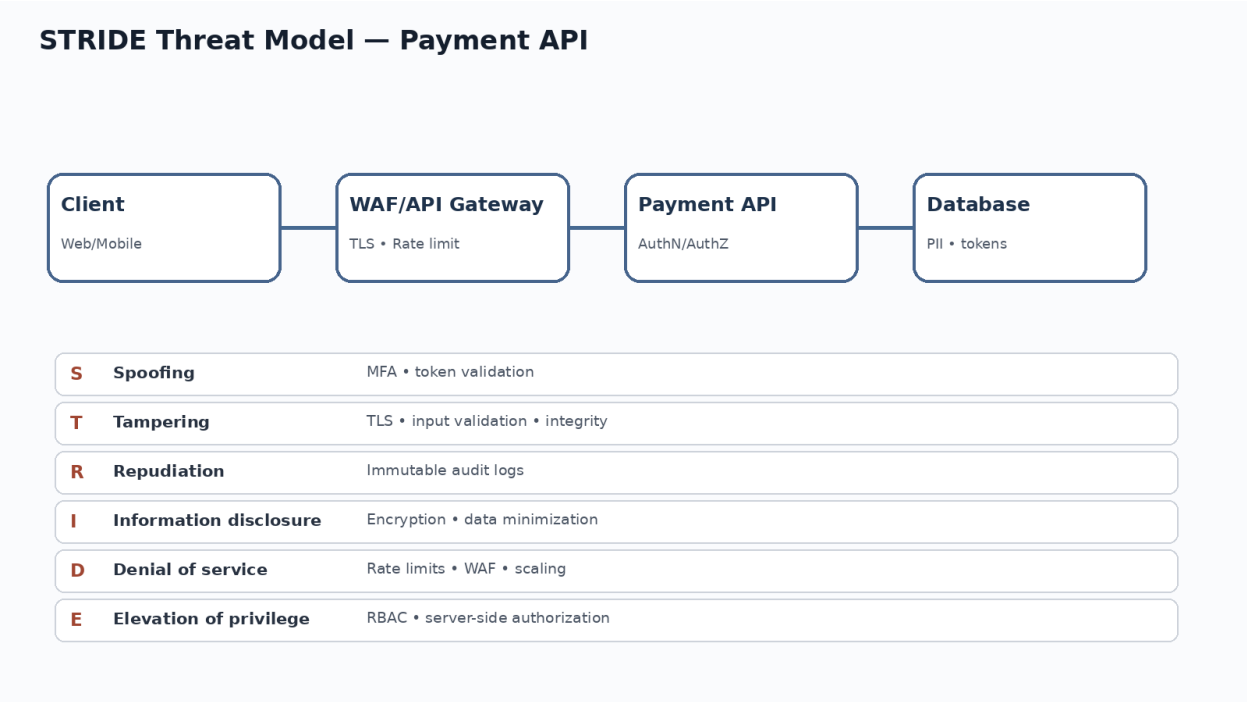


Figure 7 — STRIDE threat model for a payment API.

8.4 Secure DevSecOps Pipeline

Stage	Security Activities
Plan	Security requirements, data classification, abuse cases and threat modeling
Code	Secure coding standards, peer review, secret scanning
Build	SAST, dependency/SCA checks, artifact integrity
Test	DAST/API testing, unit/security tests, negative testing
Package	Sign/version artifacts; controlled repository
Deploy	IaC validation, approvals, least-privilege deployment identity
Operate	Runtime monitoring, vulnerability management, logging and alerting
Improve	Incident lessons, metrics, defect trends and control tuning

9. Evidence & Submission Notes

9.1 Evidence Register

ID	Evidence	Domain	Location	Status
EV-01	Risk register	Risk management	Table 1 in report	Prepared

EV-02	Information Security Policy	Governance	Policy section	Prepared
EV-03	Asset inventory	Asset Security	Asset table	Prepared
EV-04	Encryption procedure	Asset Security	Figure 1	Lab evidence
EV-05	Security architecture	Architecture	Figure 2	Prepared diagram
EV-06	Firewall rules	Network Security	Firewall table	Prepared lab example
EV-07	Wireshark packet capture	Network Security	Figure 3	Lab evidence
EV-08	RBAC chart	IAM	Figure 4	Prepared diagram
EV-09	MFA flow	IAM	Figure 5	Lab evidence
EV-10	Vulnerability scan	Assessment	Figure 6	Lab evidence
EV-11	Penetration test template	Assessment	Template table	Prepared
EV-12	Ransomware IR plan	Operations	IR table	Prepared
EV-13	Business Continuity Plan	Operations	BCP table	Prepared
EV-14	Threat model	Software Security	Figure 7	Prepared diagram
EV-15	DevSecOps pipeline	Software Security	Pipeline table	Prepared

9.2 Screenshot Integrity Note

The workbook specifically permits tutorial screenshots when tools are unavailable. To avoid representing fabricated evidence as real execution, all reference figures in this report are labeled as lab evidence references and are not presented as production scan results. For final submission, attach the screenshots captured during the CISSP lab work where the evaluator requires execution evidence (for example, Wireshark, 7-Zip, OpenVAS/Greenbone, or the MFA test account mfa.test@securepay.local).

9.3 Recommended Genuine Evidence to Capture

- A real 7-Zip encryption screen showing a non-sensitive CEH_Test_File.txt and AES-256 selection.
- A real Wireshark capture with the tcp filter and visible SYN/SYN-ACK/ACK packets from a CISSP-CEH-LAB.
- A real vulnerability scanner report against an intentionally authorized WEB-01 (10.20.60.20).
- A real MFA enrollment/login screen using a mfa.test@securepay.local.
- A screenshot of firewall rules from a lab firewall or network simulator.
- A screenshot of the completed asset inventory spreadsheet.

10. Conclusion

The completed practical project demonstrates the eight areas requested in the supplied workbook through a consistent fictional mid-size organization scenario. It combines risk assessment, information classification, security architecture, network controls, identity management, assessment/testing, incident

response and secure development practices. The deliverable is structured to demonstrate practical understanding and professional documentation rather than only theoretical definitions.

Before final academic submission, any lab evidence should be replaced with genuine screenshots from an authorized lab where the assignment evaluator expects proof of execution. All production or personal information should be removed or redacted from evidence.

Alignment with Workbook Evaluation Guidelines

Evaluation Area	How This Report Addresses It
Clarity and structure	Eight workbook sections, tables, diagrams and evidence register.
Practical understanding	Risk register, policy, asset classification, controls, procedures and operational plans.
Accuracy of risk/control identification	Risks are linked to treatment and representative controls.
Diagrams/configurations	Architecture, RBAC and STRIDE diagrams plus firewall lab examples.
Presentation/professionalism	Consistent headings, tables, figure captions and evidence-status labeling.

Source Basis

The supplied CISSP Practical Assignment Workbook is the basis for the structure and required activities in this report. It states that the workbook is intended to apply CISSP concepts through practical scenarios and lists the eight activity areas and evaluation guidelines.